

Summarized Description of Cyber Security Program using the NIST Framework Project:

- Designed a **comprehensive Cybersecurity Program**, aligned with the **NIST Cybersecurity Framework (CSF)**.
- Identified **critical security deficiencies**, including **lack of governance, vulnerability management, risk assessment, identity & access controls, and incident response capabilities**.
- Developed a **3-year Cybersecurity Roadmap**, prioritizing: **Governance, Risk Management, Identity & Access Management, Detection & Response, Data Security & Security Awareness Training**
- Delivered a **structured security improvement plan**, ensuring **cybersecurity maturity** aligns with **industry best practices**.

Cyber Security Program using the NIST Framework

by Shavaughn Hamilton

Norman Osborn was impressed by all the work that you've done for his organization in the past few months.

He wants you to leave your current job and become a full time Senior Cyber Security Consultant at Oscorp. He offers to double your salary!

However, he has one condition. He wants you to design a comprehensive cyber security program for Oscorp. He wants the program to :

1. highlight the current deficiencies in Oscorp's cyber security controls.
2. Create a 3-year roadmap for Oscorp to uplift their cyber security posture.

Problem:

Use the attached material:

- NIST CSF cyber security program spreadsheet
- Current state description of Oscorp's cyber security controls.

Identify

Sub-Category	Control Objective	Control description	Questions to ask	Pass/Fail	Comments
Asset Management	The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to business objectives and the organization's risk strategy.	Physical devices and systems within the organization are inventoried.	1. Do you an up to date CMDB or asset inventory of all physical (hardware) device? 2. How you perform periodic review on the CMDB to ensure that it's accurate and up to date?	Pass	CMDB Needs periodic reviews.
		Software platforms and applications within the organization are inventoried.	1. Do you an up to date CMDB or asset inventory of all software assets such as critical applications? 2. How you perform periodic review on the CMDB to ensure that it's accurate and up to date?	Fail	SaaS applications should be added to CMDB, they should be classified as per sensitivity and criticality.
		Organizational communication and data flows are mapped.	1. Do you have clear, up to date, network diagrams - including the cloud environment?	Pass	
		External information systems are catalogued.	1. Does your CMDB include Software-as-a-Service (SaaS) instance catalogue and classified as per sensitivity and criticality? 2. Do you have an up to date inventory of all third party suppliers?	Fail	Software and suppliers aren't included in the CMDB
		Resources (e.g., hardware, devices, data and software) are prioritized based on their classification, criticality and business value.	1. Are assets in the CMDB classified based on sensitivity and criticality?	Fail	
		Cybersecurity roles and responsibilities for the entire workforce and third-party stakeholders (e.g., suppliers, customers, partners) are established.	1. Are cyber security roles and responsibilities defined? 2. Is there a clear information security policy outlining roles and responsibilities for cyber security (including third part suppliers) ?	Fail	
Business Environment	The organization's mission, objectives, stakeholders, and activities are understood and prioritized; this information is used to inform cybersecurity roles, responsibilities, and risk management decisions.	The organization's role in the supply chain is identified and communicated.	1. Does the organisation have clear documentation outlining their role within their own supply chain when it comes to cyber security? This is accomplished by having a clear mapping of third-party suppliers, classifying suppliers based on criticality and sensitivity.	Fail	Oscomp does not have a process to manage cyber security supplier risk
		The organization's place in critical infrastructure and its industry sector is identified and communicated.	1. Is this organisation considered "critical infrastructure" ? Examples of this will include intelligence agencies, national communication organisations, transportation, etc. These are organisations that are part of "national security". If the answer is YES, then this needs to be documented in the information security policy and communicated clearly to senior stakeholders.	N/A	Oscomp is not a critical infrastructure organisation
		Priorities for organizational mission, objectives and activities are established and communicated.	The organisation has a clear business strategy and mission statement.	Pass	
		Dependencies and critical functions for delivery of critical services are established.	1. Does the organisation have key critical services and applications inventories and classified? 2. Does the organisation have business continuity plans and disaster recovery plans for key critical services?	Fail	Assets and supplies should be classified based on critical and sensitivity. The organisation should have a clear list of their key critical assets at minimum.
		Resilience requirements to support delivery of critical services are established.	1. Determine if the organization's business continuity and disaster recovery plans (including business impact analysis) support resilience of critical services. 2. Determine if appropriate due diligence (e.g., business continuity plans (BCP), service level agreements (SLA), Service Organization Control (SOC) reports) information is in place and reviewed to ensure resilience requirements of the organization can be met by critical third-party services.	Pass	
Governance	The policies, procedures, and processes to manage and monitor the organization's regulatory, legal, risk, environmental, and operational requirements are understood and inform the management of cybersecurity risk.	Organizational information security policy is established.	1. Does the organisation have an information security policy?	Fail	
		Information security roles and responsibilities are coordinated and aligned with internal roles and external partners.	1. Have information security roles and responsibility been documented and communicated with internal and external stakeholders (i.e. third party suppliers) ?	Fail	
		Legal and regulatory requirements regarding cybersecurity, including privacy and civil liberties obligations, are understood and managed.	1. The organisation's legal and regulatory responsibilities from an information security point of view is well documented. This includes complying with privacy laws and other cyber security regulations.	Fail	
		Governance and risk management processes address cybersecurity risk.	1. The organisation has a mature and established processes and procedures to manage cyber security risks. 2. The board of directors have oversight of information security issues (governance)	Fail	Cyber security risk are not documented. Therefore, the board has no visibility over cyber security risks.
Risk Assessment	The organization understands the cybersecurity risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals.	Asset vulnerabilities are identified and documented.	1. Vulnerability scans are conducted and vulnerabilities are analysed and documented.	Fail	Current vulnerability scans are ad-hoc. Coverage is not clear.
		Threat and vulnerability information is received from information sharing forums and sources.	1. vulnerability management program includes subscriptions to various threat intelligence sources to get information about the latest threats and vulnerabilities.	Fail	There is no cyber security team or a cyber security function to do this activity.
		Threats, both internal and external, are identified and documented.	1. Cyber security threats assessments have been conducted 2. threat actors have been identified, assessed, and documented	Fail	
		Potential business impacts and likelihoods are identified.	1. Cyber security risk assessments include business impact and likelihood as a critical step to determine the level of risk	Fail	
		Threats, vulnerabilities, likelihoods and impacts are used to determine risk.	1. Determine if the risk assessment process identifies reasonably foreseeable internal and external threats and vulnerabilities, the likelihood and potential damage of those threats, and the sufficiency of controls to mitigate the risk associated with those threats.	Fail	
		Risk responses are identified and prioritized.	1. Are recommendations/outcomes of the risk assessment process prioritised based on criticality and impact to the business?	Fail	
Risk Management Strategy	The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support operational risk decisions.	Risk management processes are established, managed and agreed to by organizational stakeholders.	1. Has the risk management process been endorsed by senior management?	Fail	
		Organizational risk tolerance is determined and clearly expressed.	1. Determine if the organization has defined and approved a cyber risk appetite statement. This will be derived from the risk tolerance of the organisation.	Fail	
		The organization's determination of risk tolerance is informed by its role in critical infrastructure and sector-specific risk analysis.	1. If the organisation is considered a critical infrastructure, then the cyber risk and overall risk tolerance should take this into consideration.	N/A	Oscomp is not a critical infrastructure organisation

Protect

Category	Control/Objective	Questions to ask	Pass/Fail	Comments
Access Control	Access to assets and associated facilities is limited to authorized users, personnel or contractors and to authorized activities and transactions.	Describe all aspects of identity and access management, including: 1. Describe the process used to manage usernames, passwords, identities 2. Describe the process to review policy 3. Do you use multi-factor authentication? 4. Do you have processes to off-board users who leave the organization? 5. Do you conduct regular user access reviews?	Fail	While the controls in use, there isn't enough controls in place to manage authentication of identity to meet two factor authentication, no approval process for requesting access to resources, shared admin password. Further improvements required
	Access to assets and associated facilities is limited to authorized users, personnel or contractors and to authorized activities and transactions.	Describe how physical access is managed: 1. Is an ID card (CCTV)? 2. Do you have physical access to rooms? (Access required to swap) 3. Do you make use of biometrics? 4. Do you use PIN for network access? 5. Is two-factor authentication required for all network access? 6. How do contractors and third party personnel access your environment?	Fail	While in use, but two factor authentication isn't in place. Contractors remote access isn't managed. Further improvements required
	Access permissions are managed, incorporating the principle of least privilege and separation of duties.	1. Are privileges assigned to least privileged users only of duties followed across the organization? 2. Do you conduct regular reviews to validate that the principle of least privilege and separation of duties are followed consistently across the organization?	Fail	
	Network integrity is protected, incorporating robust configuration and change control.	1. Ask the network team if they segment the network and how they do it.	Fail	
	Access is restricted and managed.	1. Do you conduct regular security awareness training? 2. Is there training and policy for employees who join the organization? 3. Do you enforce screen timeouts?	Fail	Pass, but the process could be improved. Employees should undergo security training at least once every 12 months. Consider reinforcing email phishing checks to further improve awareness.
	Privileged users are restricted and managed.	1. Do you have a process to manage privileged users / privileged accounts? 2. Do you use a tool to manage privileged users / privileged accounts?	Fail	There is a process to manage privileged user accounts. Admins passwords are stored.
	Access permissions are managed, incorporating the principle of least privilege and separation of duties.	1. Do you segment with third party suppliers and contractors to ensure information security standards are met? 2. Do you conduct regular security assessments on third party suppliers before onboarding? 3. Do you monitor and audit third party suppliers' security awareness training?	Fail	
	Access is restricted and managed.	1. Do you have a process to manage privileged users / privileged accounts? 2. Do you use a tool to manage privileged users / privileged accounts?	Fail	There is a process to manage privileged user accounts. Admins passwords are stored.
	Access permissions are managed, incorporating the principle of least privilege and separation of duties.	1. Do you segment with third party suppliers and contractors to ensure information security standards are met? 2. Do you conduct regular security assessments on third party suppliers before onboarding? 3. Do you monitor and audit third party suppliers' security awareness training?	Fail	Read members don't usually have email and accounts and don't get onboarded in the business Resource mailbox. Other staffs don't need change in this organization and thus the other members don't appear to know of their responsibilities as it concerns information security.
	Access is restricted and managed.	1. Do you have a process to manage privileged users / privileged accounts? 2. Do you use a tool to manage privileged users / privileged accounts?	Fail	There is a process to manage privileged user accounts. Admins passwords are stored.
Data Security	Information and records (data) are managed in accordance with the organization's information security policy, ensuring the confidentiality, integrity and availability of information.	1. Is data stored on hard drives, flash drives, etc. encrypted by default? 2. Has the organization undergone data discovery activity to discover, classify, and label data? 3. Does the organization have a data classification policy to prevent loss of data? 4. Is data stored on cloud services encrypted by default? 5. Has the organization undergone data discovery activity to discover, classify, and label data? 6. Does the organization have a data classification policy to prevent loss of data?	Fail	Data is encrypted by default on Microsoft Office files. However, data isn't been identified, classified, or labeled. There is no data classification policy.
	Information and records (data) are managed in accordance with the organization's information security policy, ensuring the confidentiality, integrity and availability of information.	1. Is data stored on hard drives, flash drives, etc. encrypted by default? 2. Has the organization undergone data discovery activity to discover, classify, and label data? 3. Does the organization have a data classification policy to prevent loss of data? 4. Is data stored on cloud services encrypted by default? 5. Has the organization undergone data discovery activity to discover, classify, and label data? 6. Does the organization have a data classification policy to prevent loss of data?	Fail	Data is encrypted by default on Microsoft Office files. However, data isn't been identified, classified, or labeled. There is no data classification policy.
	Information and records (data) are managed in accordance with the organization's information security policy, ensuring the confidentiality, integrity and availability of information.	1. Is data stored on hard drives, flash drives, etc. encrypted by default? 2. Has the organization undergone data discovery activity to discover, classify, and label data? 3. Does the organization have a data classification policy to prevent loss of data? 4. Is data stored on cloud services encrypted by default? 5. Has the organization undergone data discovery activity to discover, classify, and label data? 6. Does the organization have a data classification policy to prevent loss of data?	Fail	Data is encrypted by default on Microsoft Office files. However, data isn't been identified, classified, or labeled. There is no data classification policy.
	Information and records (data) are managed in accordance with the organization's information security policy, ensuring the confidentiality, integrity and availability of information.	1. Is data stored on hard drives, flash drives, etc. encrypted by default? 2. Has the organization undergone data discovery activity to discover, classify, and label data? 3. Does the organization have a data classification policy to prevent loss of data? 4. Is data stored on cloud services encrypted by default? 5. Has the organization undergone data discovery activity to discover, classify, and label data? 6. Does the organization have a data classification policy to prevent loss of data?	Fail	Data is encrypted by default on Microsoft Office files. However, data isn't been identified, classified, or labeled. There is no data classification policy.
	Information and records (data) are managed in accordance with the organization's information security policy, ensuring the confidentiality, integrity and availability of information.	1. Is data stored on hard drives, flash drives, etc. encrypted by default? 2. Has the organization undergone data discovery activity to discover, classify, and label data? 3. Does the organization have a data classification policy to prevent loss of data? 4. Is data stored on cloud services encrypted by default? 5. Has the organization undergone data discovery activity to discover, classify, and label data? 6. Does the organization have a data classification policy to prevent loss of data?	Fail	Data is encrypted by default on Microsoft Office files. However, data isn't been identified, classified, or labeled. There is no data classification policy.
	Information and records (data) are managed in accordance with the organization's information security policy, ensuring the confidentiality, integrity and availability of information.	1. Is data stored on hard drives, flash drives, etc. encrypted by default? 2. Has the organization undergone data discovery activity to discover, classify, and label data? 3. Does the organization have a data classification policy to prevent loss of data? 4. Is data stored on cloud services encrypted by default? 5. Has the organization undergone data discovery activity to discover, classify, and label data? 6. Does the organization have a data classification policy to prevent loss of data?	Fail	Data is encrypted by default on Microsoft Office files. However, data isn't been identified, classified, or labeled. There is no data classification policy.
	Information and records (data) are managed in accordance with the organization's information security policy, ensuring the confidentiality, integrity and availability of information.	1. Is data stored on hard drives, flash drives, etc. encrypted by default? 2. Has the organization undergone data discovery activity to discover, classify, and label data? 3. Does the organization have a data classification policy to prevent loss of data? 4. Is data stored on cloud services encrypted by default? 5. Has the organization undergone data discovery activity to discover, classify, and label data? 6. Does the organization have a data classification policy to prevent loss of data?	Fail	Data is encrypted by default on Microsoft Office files. However, data isn't been identified, classified, or labeled. There is no data classification policy.
	Information and records (data) are managed in accordance with the organization's information security policy, ensuring the confidentiality, integrity and availability of information.	1. Is data stored on hard drives, flash drives, etc. encrypted by default? 2. Has the organization undergone data discovery activity to discover, classify, and label data? 3. Does the organization have a data classification policy to prevent loss of data? 4. Is data stored on cloud services encrypted by default? 5. Has the organization undergone data discovery activity to discover, classify, and label data? 6. Does the organization have a data classification policy to prevent loss of data?	Fail	Data is encrypted by default on Microsoft Office files. However, data isn't been identified, classified, or labeled. There is no data classification policy.
	Information and records (data) are managed in accordance with the organization's information security policy, ensuring the confidentiality, integrity and availability of information.	1. Is data stored on hard drives, flash drives, etc. encrypted by default? 2. Has the organization undergone data discovery activity to discover, classify, and label data? 3. Does the organization have a data classification policy to prevent loss of data? 4. Is data stored on cloud services encrypted by default? 5. Has the organization undergone data discovery activity to discover, classify, and label data? 6. Does the organization have a data classification policy to prevent loss of data?	Fail	Data is encrypted by default on Microsoft Office files. However, data isn't been identified, classified, or labeled. There is no data classification policy.
	Information and records (data) are managed in accordance with the organization's information security policy, ensuring the confidentiality, integrity and availability of information.	1. Is data stored on hard drives, flash drives, etc. encrypted by default? 2. Has the organization undergone data discovery activity to discover, classify, and label data? 3. Does the organization have a data classification policy to prevent loss of data? 4. Is data stored on cloud services encrypted by default? 5. Has the organization undergone data discovery activity to discover, classify, and label data? 6. Does the organization have a data classification policy to prevent loss of data?	Fail	Data is encrypted by default on Microsoft Office files. However, data isn't been identified, classified, or labeled. There is no data classification policy.
Information Protection Processes and Procedures	Security policies that address personnel access, risk, confidentiality, integrity, availability, and recovery are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Security policies that address personnel access, risk, confidentiality, integrity, availability, and recovery are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Security policies that address personnel access, risk, confidentiality, integrity, availability, and recovery are in place, reviewed, and controlled in accordance with the organization's	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Security policies that address personnel access, risk, confidentiality, integrity, availability, and recovery are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Security policies that address personnel access, risk, confidentiality, integrity, availability, and recovery are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Security policies that address personnel access, risk, confidentiality, integrity, availability, and recovery are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Security policies that address personnel access, risk, confidentiality, integrity, availability, and recovery are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Security policies that address personnel access, risk, confidentiality, integrity, availability, and recovery are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Security policies that address personnel access, risk, confidentiality, integrity, availability, and recovery are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Security policies that address personnel access, risk, confidentiality, integrity, availability, and recovery are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
Maintenance	Maintenance and repairs to hardware, control and information system components are performed in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Maintenance and repairs to hardware, control and information system components are performed in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
Procedures/Processes	Procedures and processes for information security are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	
	Procedures and processes for information security are in place, reviewed, and controlled in accordance with the organization's information security policy.	1. Do you have a security policy for building and security facilities? Implemented and followed? 2. Do you have a security policy for information security? Implemented and followed? 3. Do you have a security policy for information security? Implemented and followed? 4. Do you have a security policy for information security? Implemented and followed? 5. Do you have a security policy for information security? Implemented and followed? 6. Do you have a security policy for information security? Implemented and followed?	Fail	

Detect

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Anomalies and Events	Anomalous activity is detected in a timely manner and the potential impact of events is understood.	A baseline of network operations and expected data flows for users and systems is established and managed.	1.Does the organisation have a SIEM? With a SIEM, you can capture what 'normal' (baseline) traffic looks like (so you can detect anomalies when you see something unusual).	Fail	
		Detected events are analysed to understand attack targets and methods.	1. Does the organisation have an effective process of analysing threats and alerts that are detected?	Fail	
		Event data are aggregated and correlated from multiple sources and sensors.	1. Does the organisation have an effective SIEM solutions? If Yes, Have logs been onboarded successfully to the SIEM?	Fail	
		Impact of events is determined.	1. Does the process of analysing detected events include classifying the event based on its impact and criticality? (i.e. low/medium/high for example)	Fail	
		Incident alert thresholds are established.	1. Are escalation points for alerts established based on impact/criticality?	Fail	
Security Continuous Monitoring	The information system and assets are monitored at discrete intervals to identify cybersecurity events and verify the effectiveness of protective measures.	The network is monitored to detect potential cybersecurity events.	1.Is network traffic monitored for malicious activity? (this is accomplished by having an operational SIEM).	Fail	
		The physical environment is monitored to detect potential cybersecurity events.	1. Does Security events monitoring include the physical security environment? Do you get alerts for physical security breaches?	Pass	
		Personnel activity is monitored to detect potential cybersecurity events.	1. Do you detect unusual and/or malicious activities across the organisation (including physical breaches) ?	Fail	
		Malicious code is detected.	1. If you perform software development activities, do you conduct secure coding scanning? 2. Do you have an anti-malware solution (like Microsoft Defender or crowdstrike, for example) ? 3. What's the coverage of your anti-malware solution? Is it deployed on all end-points? what about servers? do you have Mac-OS ? Is it deployed on Linux machines?	Pass	
		Unauthorized mobile code is detected.	1. Do you have an anti-malware solution? Does it scan emails as well as static files?	Pass	
		External service provider activity is monitored to detect potential cybersecurity events.	1. Do you have comprehensive TPRM process? If yes, Do third-party service providers provide you with notification in case of any data breaches? (this should be part of the contract)	Fail	
		Monitoring for unauthorized personnel, connections, devices and software is performed.	1. Can any random devices be hooked and connected to the network or do you only allow registered devices that were configured by your IT team to be connected? (best practice is to only allow devices that meet the minimum security requirements of the organisation) 2. Do you allow USB flash drives in the environment?	Fail	
Detection Processes	Detection processes and procedures are maintained and tested to ensure timely and adequate awareness of anomalous events.	Vulnerability scans are performed.	1. Do you conduct regular vulnerability scans? If yes, what's the coverage of your vulnerability scanner?	Pass	Further improvements needed
		Roles and responsibilities for detection are well defined to ensure accountability.	1. have you defined roles and responsibilities for detection and response? Are they assigned to the IT team or cyber security team? Are the roles clear? Do you use MSSP? Is there a clear contract?	Fail	
		Detection activities comply with all applicable requirements.	1. Is your detection capabilities compliant with rules and regulations that are applicable to your organisation?	Fail	
		Detection processes are tested.	1. Do you perform effectiveness testing against your detection use cases? This can be cyber drills and penetration tests 2. Do you improve your detection use cases based on the test outcomes?	Fail	
		Event detection information is communicated to appropriate parties.	1. Do you have clear communication paths and escalation points for when events are detected? Are they documented?	Fail	
		Detection processes are continuously improved.	1. Do you incorporate 'lessons learned' as part of your incident response? Is there a process to continuously improve detection capabilities?	Fail	

Response

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Response Planning	Response processes and procedures are executed and maintained, to ensure timely response to detected cybersecurity events.	Response plan is executed during or after an event.	1. Do you cyber security incident response plans? IF yes, are they actively used during an incident?	Fail	
Communications	Response activities are coordinated with internal and external stakeholders, as appropriate, to include external support from law enforcement agencies.	Personnel know their roles and order of operations when a response is needed.	1. Do incident response plans include clear contact details and escalation points? Have they been tested?	Fail	
		Events are reported consistent with established criteria.	1. Do cyber security incidents get reported as per the defined threshold? How mature is the incident response process?	Fail	
		Information is shared consistent with response plans.	1. Do Incident response plans include clear and transparent escalation in points? If yes, do they include involving law enforcement (when necessary) ?	Fail	
		Coordination with stakeholders occurs consistent with response plans.	1. For escalated incidents, do response plans include details on how to coordinate with various teams when necessary?	Fail	
		Voluntary information sharing occurs with external stakeholders to achieve broader cybersecurity situational awareness.	1. Does your organisation share information security intelligence with the wider community or with industry peers?	Fail	
Analysis	Analysis is conducted to ensure adequate response and support recovery activities.	Notifications from detection systems are investigated.	1. Does your team has a clear process to respond to security alerts? 2. Do you have 24/7 coverage?	Fail	
		The impact of the incident is understood.	1. Does your team document the impact/criticality of incidents as part of their analysis?	Fail	
		Forensics are performed.	1. Does your team have the capability (people/skills and technology) to perform digital forensics analysis when needed?	Fail	
		Incidents are categorized consistent with response plans.	1. Are your incident response plans well structure in a such a way that they prioritise incidents based on criticality?	Fail	
Mitigation	Activities are performed to prevent expansion of an event, mitigate its effects and eradicate the incident.	Incidents are contained.	1. Ensure Incident response plans follow a standard that ensure that incidents are contained. (such as the SANS incident response plans template)	Fail	
		Incidents are mitigated.	1. Ensure Incident response plans follow a standard that ensure that incidents are mitigated as needed. (such as the SANS incident response plans template)	Fail	
		Newly identified vulnerabilities are mitigated or documented as accepted risk.	1. Do you have a comprehensive vulnerability management program that accounts for new vulnerabilities that are newly discovered (including zero days)? Do you have a process to dealing with them?	Fail	
Improvements	Organizational response activities are improved by incorporating lessons learned from current and previous detection/response activities.	Response plans incorporate lessons learned.	1. Do your incident response plans include a "lessons learned" step?	Fail	
		Response strategies are updated.	1. Do you periodically test and update your incident response plans?	Fail	

Recover

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Recovery Planning	Recovery processes and procedures are executed and maintained to ensure timely restoration of systems or assets affected by cybersecurity events.	Recovery plan is executed during or after an event.	1. Does your organisation have a disaster recovery plan? Has it been tested?	Pass	
Improvements	Recovery planning and processes are improved by incorporating lessons learned into future activities.	Recovery plans incorporate lessons learned.	1. Do your disaster recovery plans include a "lessons learned" step?	Pass	
		Recovery strategies are updated.	1. Do you perform periodic testing for your disaster recovery plans? Do they get regularly updated as a result?	Pass	
Communications	Restoration activities are coordinated with internal and external parties, such as coordinating centres, Internet Service Providers, owners of attacking systems, victims, other CSIRTs and vendors.	Public relations are managed.	1. Do you improve communication as part of your disaster recovery testing?	Pass	
		Reputation after an event is repaired.	1. Do your disaster recovery plans include a mitigating steps in case of a crisis where the reputation of the organisation is impacted?	Pass	
		Recovery activities are communicated to internal stakeholders and executive and management teams.	1. Do your disaster recovery plans include clear communication and escalation points?	Pass	

Shavaughn Hamilton's Practical Assessment Solution: Cyber Security Program using the NIST Framework

1. Highlight the current deficiencies in Oscorp's cyber security controls.

Organizational governance:

Roles and responsibilities for cyber security haven't been defined.

There is no formal vulnerability management program in place.

Vulnerability management:

The IT team uses Qualys on an ad-hoc basis

There is no formal vulnerability management program in place

Large number of high and severe vulnerabilities reported by Qualys

Risk Management:

There is no cyber security strategy.

Third Party Risk Management:

Oscorp doesn't perform any third-party risk management.

Contracts are reviewed by procurement and finance, not IT.

Identity and Access Management:

There is no privileged access management solution in place

Admin account password is shared with a few senior members of the IT team

Access to resources is granted upon request

The organization does not use two-factor authentication for login

Data Security:

Oscorp doesn't have a DLP solution

Policy:

There is one generic IT policy in place

No formal information security policy

There is no data governance policies or information classification

Cyber Security detection and response:

There is no detection or response capability

The IT team responds to alerts from the anti-virus (Microsoft Defender)

No SIEM in place

Security Education and Awareness:

All employees are required to do an induction web training module. The module includes basic instructions about cyber security.

2. Create a 3-year roadmap for Oscorp to uplift their cyber security posture.

The following are a set of recommendations based on the NIST assessment that I conducted.

The recommendations are prioritized in order of importance.

Key Areas of Improvements:

Cyber Security Governance:

- Hire a Cyber security manager or a Chief information security manager.
- Formalize cyber security roles and responsibilities. Ensure that the board of the directors are awareness of their information security duties
- Draft a comprehensive information security policy. Endorse the policy by senior management.
- Invest in hiring cyber security professionals to establish and manage a cyber security practice.
- Define specific roles and responsibilities for cyber security team
- Create a formal vulnerability management program
- There should be an industry framework policy in place
- Implement a formal information security policy
- Implement data governance policies or information classification

Vulnerability Management:

- Weekly scheduled scans and reports from Qualys during peak activity times (Not weekends and evening hours)
- A formal vulnerability management program put into place
- Find out the reason and address the large number of high and severe vulnerabilities reported by Qualys

Asset Management:

- Identify and classify all assets based on criticality and sensitivity
- Conduct periodic reviews to ensure the CMDB is accurate and up to date

Third Party risk management:

- Create a process to identify and manage third party suppliers. The process should start by identifying suppliers, classifying suppliers, and conducting periodic security assessments on third party suppliers

Cyber Security Risk Management:

- Develop a cyber security strategy.
- Create a process to assess and manage cyber security risks.
- The process should prioritize risks based on criticality and impact to the business.
- The process should be endorsed by the audit and risk committee and the current risk management team
- Create a cyber security risk register to document all cyber security risks
- Recommend an internal audit program to include cyber security in the scope

Identity and Access Management:

- Implement and roll-out two factor authentication across the organization as a priority
- Follow the principle of least privileges and separation of duties across the organization
- Review admin users, eliminate sharing of admin passwords and implement a role based access control
- Conduct regular user access reviews to ensure that access management principles are consistently followed
- Privileged access management solution should be set in place
- Access to admin account should require Privileged Access Management (PAM) where permission from multiple administrators is required for access for a limited time
- Access to resources should be granted based on the necessity to fulfill specific tasks
- Organization needs to implement at least a two-factor authentication for login

Security Education and Awareness:

- Implement up to date, regular trainings for employees
- Employees should undergo security training at least once every 12 months
- Consider running simulated phishing attacks to further improve awareness

Data Security and DLP:

- Oscorp needs to implement a DLP solution
- Undertake a data discovery activity. Classify and label data based on sensitivity and criticality.
- Utilize Microsoft Azure AIP to label data
- Consider implementing a DLP solution. A Microsoft DLP solution might be the best solution as the environment uses Microsoft products.
- Block USB flash drive usage. Only allow it (temporarily) when there is a business justification.

Detection and Response:

- Implement detection and response capability
- The IT team responds to alerts from the anti-virus (Microsoft Defender)
- Invest in a SIEM solution. This could be using a Managed Security Service Provider (MSSP) or in house. Detecting cyber security incidents is a priority.
- Create an enterprise-wide cyber security incident response plan and at least 5 x cyber security incident response plans for the most common attack type.